

Manual 03 - Roles y Permisos (RBAC)

Version: 1.1

1) Explicacion no tecnica

Que es RBAC en este proyecto

RBAC significa que cada rol entra a una "version controlada" de la app:

- ve solo lo que necesita
- hace solo lo que tiene permitido

Ejemplo no tecnico

Escenario:

- Un trabajador quiere eliminar un usuario.

Resultado esperado:

- No ve la opcion y no puede ejecutar esa accion.

Escenario:

- Un supervisor abre Usuarios.

Resultado esperado:

- Puede revisar informacion, pero no tiene acciones administrativas completas.

2) Explicacion tecnica

Fuente unica de verdad

Archivo: src/service/permissions.js

Este archivo define:

- ROLES
- PERMISSIONS
- rolePermissions (matriz rol -> permisos)
- helpers de alto nivel (canViewUsers, canViewAnyTasks, etc)

Matriz resumida por rol

ADMIN / ADMINISTRADOR:

- Gestion total de usuarios, apartamentos, tareas, dashboard y kanban.

SUPERVISOR:

- Lectura de usuarios.
- Gestion operativa de tareas y checklist.
- Acceso a dashboard y kanban.

TRABAJADOR:

- Tareas propias.
- Cambio de estado/checklist en tareas asignadas.
- Kanban personal.

Helpers clave

- hasPermission(permission)
- canViewAllTasks()
- canViewOwnTasks()
- canEditSpecificTask(task)
- filterTasksByPermissions(tasks)
- canViewAnyTasks()
- canViewAnyKanban()

3) Ejemplos tecnicos concretos

Ejemplo A - Filtro de tareas

Entrada:

- Rol actual: TRABAJADOR
- tasks: 12 tareas mezcladas

Proceso:

- filterTasksByPermissions(tasks)
- internamente usa isTaskOwner(task)

Salida esperada:

- solo tareas asignadas al usuario autenticado

Ejemplo B - Propietario por distintos formatos

isTaskOwner(task) soporta:

- task.assignedUsers[]
- task.assignedUserId
- task.usuarioAsignadoId
- task.assignedUser.email

Esto cubre variaciones de contratos backend.

Ejemplo C - Menu lateral

Sidebar consulta canViewUsers().

Si false:

- no renderiza link de Usuarios.

Si true:

- renderiza link de Usuarios.

4) Donde impacta RBAC

- Navegacion: que links existen.
- Datos: que registros se ven.
- Acciones: que botones/operaciones aparecen.
- Dashboard: vista admin vs vista trabajador.

5) Diferencia entre control UI y seguridad real

Frontend RBAC:

- evita confusion y acciones no deseadas desde la interfaz.

Backend seguridad:

- impide tecnicamente operaciones no autorizadas (aunque alguien intente llamar API directo).

Ambas capas deben existir.

6) Checklist para cambiar permisos

1. Modificar rolePermissions en permissions.js.
2. Revisar helpers dependientes.
3. Probar Sidebar con cada rol.
4. Probar Task/Kanban/Home con cada rol.
5. Verificar reglas equivalentes en backend.